保额罗盘
InsureCompass

系统架构、核心算法与安全设计

AI 家庭保险保障体检助手

面向家庭经济责任场景，将定期寿险和重疾险的需求拆成可核对的财务项目；金额由确定性公式计算，AI 通过服务端接口解释结果与假设。

产品范围

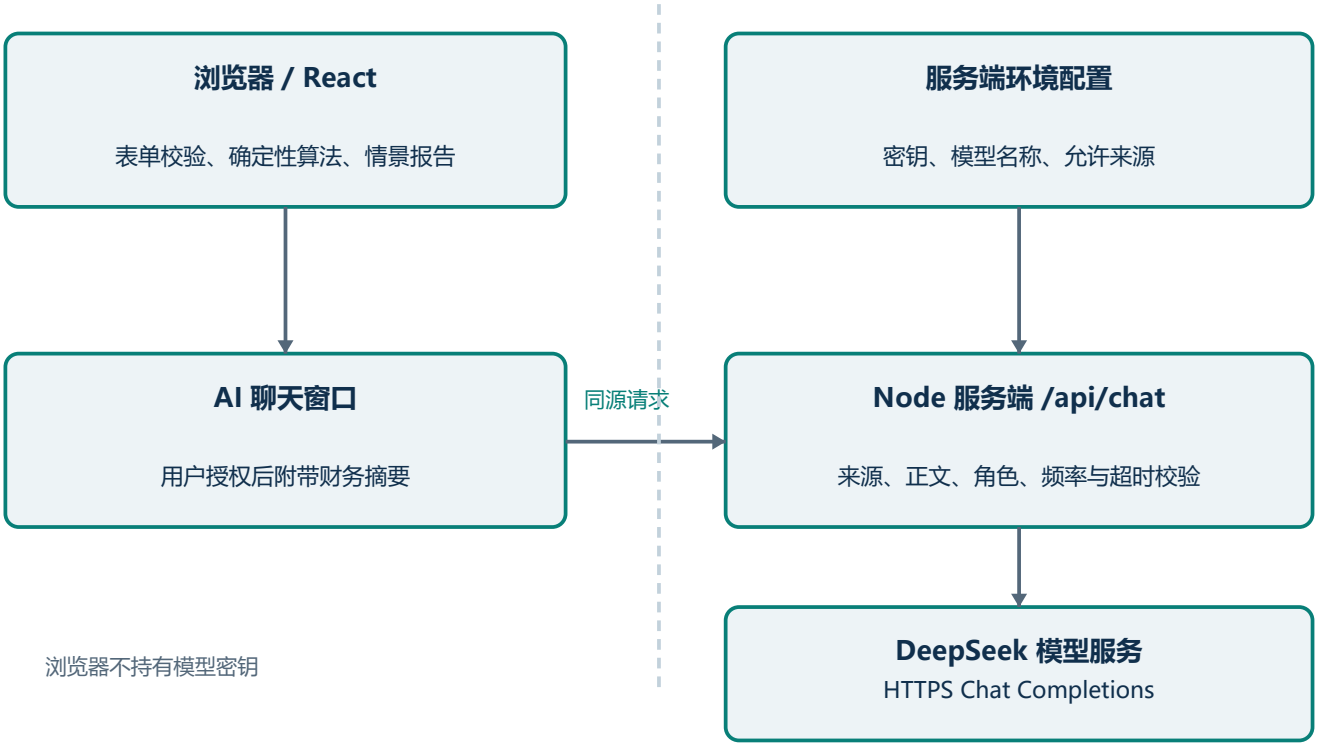
输入年龄、收入、房贷、家庭人数、受扶养人数、已有保障和高级参数，输出参考目标、缺口、覆盖率及构成。支持乐观、基准、谨慎情景、公式明细和浏览器打印报告。

模块	实现方式
前端	React 18 + TypeScript + Vite；Tailwind 和 Recharts 展示
计算层	浏览器内纯函数测算，独立于模型服务
服务端	Node.js 24 提供静态构建与同源 /api/chat
模型接口	服务端 HTTPS 调用 DeepSeek；已完成真实问答、上下文与多轮联调

阅读范围

后续章节依次说明架构与数据流、两类保障公式、情景与资产约束、安全权限，以及验证与部署。本文描述当前仓库实现；不将模型解释当作精算、报价或承保结论。

01 系统架构与数据流



本地测算路径

用户输入 → 输入校验 → calculateInsurance → 结果卡、情景图表和公式明细。页面不调用模型生成金额；没有 AI 配置时，测算仍可运行。

授权解释路径

聊天窗口默认关闭财务同步。用户授权后，问题、近期对话和基准测算摘要发往同源 /api/chat；服务端校验并用服务端凭据请求 DeepSeek，向浏览器只返回回答及必要状态。

部署与数据边界

不设置应用数据库，不主动持久化家庭输入或对话。服务器只公开 dist 静态文件和聊天接口，源文件与环境文件不在静态目录中。反向代理的访问日志及模型供应商的数据政策属于部署侧管理范围。

对应代码：src/pages/HomePage.tsx；src/utils/calculator.ts；src/services/aiService.ts；server/index.mjs；server/chat-handler.ts。

02 定期寿险参考目标与缺口

计算口径

本模型按家庭责任需求拆解，以万元为金额单位。必要家庭年支出应避免再次包含计划一次性清偿的同一笔房贷本金，降低重复计入风险。

G = 有受扶养人时 max(0, E - C)，否则为0

D = M × s + G × Y + B + R

T = max(0, D - A)

Gap = max(0, T - L)

符号	含义
E / C	家庭必要年度开支 / 其他成员每年承担开支
M / s	剩余房贷本金 / 本人承担比例（0至100%）
Y / B / R	实际情景支持年限 / 其他债务 / 教育赡养专项储备
A / L	分配给定寿风险的可用资产 / 已有有效身故保额
D / T / Gap	总需求 / 保险参考目标 / 待补保障缺口

标准验收样例

房贷100万、责任比例100%；受扶养2人，必要年支出12万，其他成员承担0万，支持10年；其他债务和专项储备均为0。总需求 = 100 + 12 × 10 = 220万。

抵扣定寿资产20万 → 参考目标200万；再扣已有身故保额50万 → 待补缺口150万。覆盖率为25%。

年龄与人数的作用

年龄用于18至70岁的整数校验；家庭总人数用于关系校验；受扶养人数大于0时才计生活支持责任。未按年龄、人数直接乘算保额，不估计死亡概率或保险价格。

03 重疾险参考目标与缺口

$$H = F + I \times Z + Q$$

$$T = \max(0, H - A)$$

$$Gap = \max(0, T - L)$$

符号	含义
F / Q	治疗自费储备 / 康复照护储备
I / Z	本人税后年收入 / 当前情景收入中断年限
A / L	分配给重疾风险的资产 / 已有有效重疾给付保额

样例与保障边界

年收入20万、收入中断2年、治疗储备30万、康复储备10万，需求为30 + 20 × 2 + 10 = 80万；未分配重疾资产、已有重疾20万时，缺口60万。报销型医疗险不能直接作为重疾给付保额抵扣。

可调整的默认假设

参数	默认值	性质
必要年支出	年收入的60%	缺省估算，可改为实际预算
家庭支持年限	有受扶养人10年，否则0年	责任规划假设
房贷责任	100%	应按实际协议调整
治疗 / 康复储备	30万 / 10万	项目假设，不代表医疗费用预测
收入中断	2年	可调整为0至10年

金额语义

结果是给定假设下的需求估算。未计通胀、贴现、社保给付、核保条件或保费负担能力。显示金额保留0.01万元精度，不能当作精确到元的财务结算。

04 情景、资产与边界处理

规则	乐观	基准	谨慎
支持年限	通常减3年，下限3年；不超过基准	用户输入	有受扶养人时加5年
收入中断	基准×0.75，下限1年；不超过基准	用户输入，保留0	max(3年, 基准×1.5)
治疗 / 康复	基准×0.8	用户输入	基准×1.3

标准样例的情景结果（万元）

情景	定寿目标 / 缺口	重疾目标 / 缺口
乐观	164 / 114	62 / 42
基准	200 / 150	80 / 60
谨慎	260 / 210	112 / 92

资产分配与输出限制

两类风险的资产分配之和不得超过可动用资产；超额时按比例缩放。总资产为0时两类抵扣归零，已有保障超过目标时缺口归零。此约束是项目采取的保守资源分配政策。

回归修复

收入中断为0时，基准不再误用2年默认值；乐观情景也保持0。短支持期不被乐观情景提高到3年。谨慎情景明确改变假设，可能提高原先为0的停工年限，报告显示变更后的实际年限。

输入与公式一致性

拒绝非有限、负数、超范围金额，以及不合法人数、房贷责任比例和年限。报告公式使用当前情景实际年限。用户自定义家庭开支后，调整收入不再覆盖该项。

05 安全设计与权限边界

层级	允许操作	限制或控制
访客	填写、测算、打印；向AI提问	默认不发送财务摘要，无配置修改入口
服务进程	读取密钥并调用固定配置的模型接口	凭据不进入网页；不回传上游原始错误
部署维护者	通过主机/托管平台配置、更新、轮换凭据	依赖部署平台访问控制；应用没有管理员后台

已实现的接口约束

Origin 精确白名单；POST 只接受JSON；正文最多16KiB；对话最多12条、每条1500字符且只允许user/assistant；上下文最多6000字符；单实例每分钟30次有效请求、最多2个上游并发；上游调用20秒超时。

浏览器与隐私

静态服务设置CSP、禁止嵌入、禁止MIME嗅探及不发送来源的策略；聊天响应不缓存。没有姓名、身份证、病史等必填字段，不使用应用数据库保存输入。对话以文本渲染，默认不启用财务摘要授权。

安全边界

来源白名单不等于身份认证，非浏览器客户端仍可伪造Origin；实例限流不等于全局配额。部署需配合账号费用预算和公网入口保护。模型仍可能受提示注入影响或产生错误，其回答不覆盖确定性报告。

06 验证结果与交付部署

验证项	范围与结果
自动测试	34项通过：18项算法/校验、2项服务降级、14项接口处理
类型与构建	前端和后端处理器类型检查通过，生产构建通过
浏览器	标准金额、情景与明细、边界、授权、参数保留、手机视口及PDF导出
真实模型	DeepSeek概念问答、授权上下文解释及多轮追问通过
依赖审计	本次检查报告0项已知漏洞，不等同于不存在未知漏洞

源码交付与运行

源码包包含README、部署说明、锁文件、测试、前后端源码和dist构建产物。Node.js 24可直接运行 npm start 查看构建；修改或重建时执行 npm ci 与 npm run verify。模型密钥在服务端配置，公开访问还需HTTPS和实际域名来源白名单。

验证限制

未进行多实例压测、独立渗透测试或全浏览器认证。当前记录验证了本地生产构建，不预设公网域名。主脚本约753kB，仍存在构建体积提示；可后续按需加载图表。

资料依据与可追溯性

主要依据为当前源码与 docs/TESTING.md 中的实际验证。NAIC寿险消费者资料支持考虑收入、债务和受扶养责任等因素，不为本项目默认比例或储备金额背书。

参考：
https://content.naic.org/consumer/life-insurance.htm
https://vite.dev/guide/build.html
https://api-docs.deepseek.com/